

Demo: Syft & Grype

Automating Supply Chain Security and Vulnerability Quality Gates

KTH DD2482 (Week 6) • Ignacy Stępniewski & Sébastien Rivière

Supply Chain Security

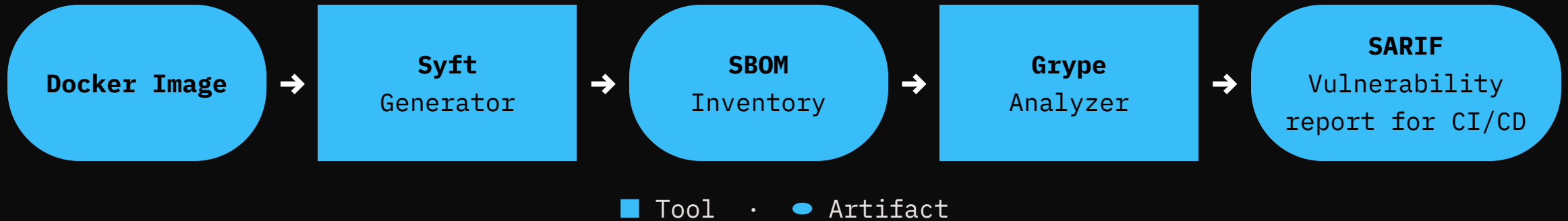
The Hidden Risk

→ **Application & Dependencies:** requirements.txt
pip

→ **Operating System & Base Image:** apt apk
Dockerfile

UNIX Philosophy

Each tool does one job and passes its output to the next, from image to CI/CD report.



Precisions, Trade-offs and Conclusion



Scanner Limits

Data freshness

A scanner is only as good as its latest update.

System overhead of about ~2 min per PR to prevent supply chain attacks.



Pipeline Pragmatism

False positives & upstream CVEs

Manage vulnerabilities without a fix (unfixable upstream) so development isn't blocked.

Use `--only-fixed` or `.grype.yaml`



Defense in Depth

Runtime security

Static analysis is imperfect. It must be paired with runtime protections.

Non-root user Read-only filesystem